Shawn Ray
Carnegie Mellon University
Pittsburgh, PA 15213, USA
shawnray@cmu.edu

November 2, 2026

The Editor-in-Chief
IEEE Transactions on Dependable and Secure Computing

Re: Submission of the regular paper "What Can Be Enforced? Limits of Runtime Guardrails for Tool-Using LLM Agents"

Dear Editor-in-Chief,

I am pleased to submit the above manuscript for consideration as a regular paper in *IEEE Transactions on Dependable and Secure Computing*.

Tool-using language-model agents send email, move money, and edit files while reading untrusted content, and deployments increasingly rely on a runtime guardrail, a judge-driven gate in front of each tool call, as the security boundary against prompt injection and misuse. Guardrail evaluations report violation rates, but not which policies a gate can enforce, what a calibrated certificate guarantees, or when that guarantee fails. The manuscript answers these questions with three boundaries, each stated with the regime in which it holds, and tests their empirical consequences.

Contributions.

- *Expressiveness.* A model of pre-execution gates over irreversible, data-carrying tool calls that exactly characterizes the policies enforceable relative to fixed oracle predicates: the nonempty safety policies whose good prefixes the gate's register automaton recognizes, strictly fewer than edit automata enforce.
- *Statistics, adversaries, and feedback.* For fallible judges: for a fixed exogenous decision, the exact Neyman–Pearson miss/false-block frontier, a finite-sample conformal certificate and the robustness margin that bounded attacks on judge inputs add to it, and a proof that static scores and ungated trajectories cannot identify the closed-loop frontier once blocks change later proposals, whereas logs with known exploratory blocking can, with an occupancy program for specified finite models.
- *Decidability.* Whether a policy can ever fire is undecidable with two decrementable, zero-testable counters, PSPACE-complete for a keyed-counter fragment, and NP-complete for caps, quotas, and revocation (no data registers, amount tests that are cap checks), so a complete linter for them is one SMT query.
- *Evaluation.* A study of 33 judge runs on AgentDojo instruction strings; an in-context study in which seven hosted judges score ground-truth tool calls with and without the user task and tool outputs; two prompt-injection detector baselines; representation attacks (a predeclared suffix, query-adaptive rewrites, and an optimizing score-feedback attacker, on instruction strings and inside the injection itself); closed-loop agent runs; and the cost of exact enforcement. What the judge sees dominates: in context the judges reach AUC .950–1.000 and calibrated gates block at most 5.3% of clean compliant calls, against .661–.842 and 44–93% for the same calls serialized alone. Context buys discrimination, not verified robustness: rewriting only the injection evades those gates stably on up to 12% of flagged calls, and an optimizing attacker evades even the expensive instruction-string gates on 27–35% of flagged violations. The best context-free gate calibrated on 17–18 violations blocks 64% of compliant instructions (95% CI 20–83%; 33% with exact-level randomized calibration). A compiled keyed-counter gate decides in a sub-microsecond median, about six orders of magnitude faster than one hosted judge call.

Fit with TDSC. The paper treats a guardrail as a dependability mechanism: in the taxonomy of Avižienis, Laprie, Randell, and Landwehr (TDSC, 2004), the gate contains errors before they become irreversible failures, misses

are security and safety failures, and false blocks are omission failures that cost availability. The results combine runtime enforcement and security automata, statistical guarantees for fallible detectors, adversarial robustness of those detectors, and decidability of policy analysis, all topics central to this journal, and end in concrete guidance for practitioners, including a "certificate card" that states what any guardrail evaluation must report before its numbers can support a security claim.

Prior version. An earlier version of this work is available as arXiv:2607.22868 (July 24, 2026, "What Can Be Enforced? A Theory of Certified Runtime Safety for Tool-Using Agents"). The manuscript has not been published and is not under consideration elsewhere. Relative to the preprint, the submission

- is retitled and restructured for the journal, with every result and headline number in the main text and complete proofs, the full evaluation, and extended related work in the supplementary material;
- unifies the evaluation into one study of 33 judge runs that adds late-2026 frontier judges, familywise (max-T) inference against a predeclared reference judge, and a content-benign sensitivity analysis;
- re-analyzes the representation attack over all 35 violations for 21 judges with simultaneous intervals, extends the template search to the new judges, and adds a predeclared query-adaptive search, both measured at a high-utility flagged-subclass threshold;
- adds a converse to the non-identifiability result: logs from a gate that both blocks and allows with known probabilities of at least ε at every reachable history restore identification of the closed-loop frontier, at a variance cost that can grow exponentially in the horizon, checked by simulation on the two-system model;
- adds a matching PSPACE lower bound (one equality-register component suffices, by the standard register-automaton argument of Demri and Lazić), so nontriviality of the keyed-counter fragment is PSPACE-complete; proves that for caps, quotas, rate limits, and revocation (no data registers, cap-check amount tests) nontriviality is NP-complete, decidable by one existential Presburger (SMT) query, and that dropping the cap-check condition restores PSPACE-hardness; and shows that rule redundancy (policy inclusion) is PSPACE-complete when the allowing side has no key-local component, and coNP-complete for these cap-check rules;
- adds an in-context tool-call evaluation on AgentDojo ground-truth traces (with a context ablation and a tagless-injection variant), query-adaptive attacks on the in-context gates, a predeclared optimizing (PAIR-style) attacker on the calibrated gates, and prompt-injection detector baselines (ProtectAI DeBERTa-v3, PIGuard);
- adds a guardrail certificate card with red flags and a verdict, a fill-in template and JSON schema in the artifact, and the card's fields for all 33 judge runs (Supplement D);
- adds a new experiment on the cost of exact enforcement and specification analysis (compiled gate latency, a differential check against a naive replay monitor, hosted-judge latency, and a cap-redundancy check built on the T3 saturation abstraction);
- adds the dependability and reference-monitor framing and related work updated through 2026, including work published in this journal.

Supplementary material and artifact. Following the Computer Society's policy that appendices are supplemental material, a separate file contains complete proofs (Supplement A), extended experiments (Supplement B), reproducibility details (Supplement C), an extended survey of related work (Supplement D), and the full evaluation (Supplement E). Code, our curated probe, and cached judge scores are public at https://github.com/shawnray-research/certified-agent-guardrails/tree/tdsc, except the per-episode logs of the paired closed-loop rerun and the source-role cache (Supplement C); the tables and figures built from the cached scores regenerate without model inference.

Thank you for considering this manuscript. I look forward to the reviewers' comments.

Sincerely, Shawn Ray, Carnegie Mellon University